Auditoría exhaustiva de seguridad, privacidad, accesibilidad y robustez

Proyecto: Gestor financiero / Portafolio Intel

Fecha: 26 de agosto de 2026

Autor: Manus AI

Naturaleza: auditoría local de código, compilación, pruebas y recorridos con datos ficticios. No es una certificación, un pentest externo ni una validación de producción.

> **Dictamen.** La aplicación dispone de controles valiosos y verificables para el modo local —aislamiento de red, límites de archivo, Worker, validación tipada y restauración JSON atómica— y la arquitectura declarada de RLS mantiene una dirección correcta. Sin embargo, **no debe describirse todavía como robusta y segura en todos los flujos** hasta corregir la inyección de fórmulas CSV, la aceptación de fechas cripto inexistentes, la recarga integral bajo Realtime y los casos de integridad del bootstrap privilegiado. También faltan cabeceras de seguridad verificadas en el entorno de despliegue, pruebas E2E y una comprobación actual de las políticas RLS del proyecto remoto.

1. Alcance, método y límites

La auditoría revisó el código local disponible en `/home/ubuntu/gestor_financiero`: Next.js 16.3.1, React 19, Supabase JS, Worker del Canvas, importadores/exportadores, FIFO de cripto, análisis financiero, funciones Edge y declaraciones de migración/RLS. Se inspeccionaron los archivos de entorno **solo por nombre de variable**; no se leyeron ni revelaron secretos. No se usaron datos financieros personales, credenciales, documentos privados ni cuentas autenticadas.

El método combinó revisión estática, ejecución de comandos ya existentes, regresiones deterministas, comprobaciones aisladas de bordes y recorrido visual del Canvas con el ejemplo ficticio integrado. La clasificación usa las definiciones siguientes: **Alto** para una exposición o cálculo financiero incorrecto reproducible; **Medio** para una degradación relevante, brecha de defensa o integridad; **Bajo** para deuda de calidad; e **Información** para controles positivos o límites no explotados.

Superficie revisada	Evidencia obtenida	Límite de la revisión
Código Next/React	Lectura de componentes, motores y estilos.	No se hizo un pentest de navegador ni revisión de todas las dependencias transitivas.

Supabase y Edge Function	Lectura de cliente, función `bootstrap-organization` y SQL declarado.	No se ejecutó DDL ni se hizo una nueva consulta al proyecto remoto durante esta auditoría.
Privacidad local	Flujo visual, recursos del navegador y revisión de Canvas/Worker.	La verificación cubre el ejemplo ficticio en desarrollo, no todos los navegadores.
Cálculos financieros y fiscales	Pruebas existentes y casos de borde añadidos temporalmente.	No valida exactitud fiscal o de mercado; los resultados siguen siendo borradores revisables.
Accesibilidad	Semántica, foco visible, atributos ARIA y recorrido del Canvas.	No se ejecutó lector de pantalla ni auditoría automatizada de contraste/móvil.
Despliegue	Cabeceras de `localhost` y configuración local.	Un proxy/host de producción puede aplicar políticas adicionales no visibles aquí.

2. Línea base reproducible

Comprobación	Resultado	Interpretación
`npm run lint`	Correcta.	No se detectaron infracciones ESLint con la configuración presente.
`npm run build`	Correcta.	Compilación, TypeScript y prerenderizado locales completados.
`npm audit --omit=dev --audit-level=high`	`0 vulnerabilities`.	No se encontraron vulnerabilidades de producción conocidas por el registro de npm en este momento; no sustituye revisión de configuración ni de dependencias futuras.
Regresión cripto	Correcta.	FIFO, permutas, inventario insuficiente y cadena de permutas se mantienen en las rutas cubiertas.
Regresión de auditoría	Correcta.	Se conservan el consumo atómico de plataformas y los

		filtros de fecha europeos del Canvas.
Regresión de validación local	Correcta.	Fechas reales ISO/europeas, importes y texto de celdas del Canvas se validan.
Regresión Salud empresa	Correcta.	Fórmulas y estados no significativos cubiertos por esa prueba.

Las pruebas directas con `node --experimental-strip-types` emitieron avisos de soporte experimental y de resolución ESM; no invalidan el build de producción, pero prueban que la ejecución de regresiones aún no está integrada en una cadena estable de CI.

3. Resumen ejecutivo de hallazgos

ID	Severidad	Estado	Resumen
AUD-2026-01	**Alto**	Verificado	Exportaciones CSV del Canvas y de cripto permiten células que comienzan por caracteres de fórmula.
AUD-2026-02	**Alto**	Verificado	El importador FIFO acepta fechas de calendario imposibles y las trata como operaciones válidas.
AUD-2026-03	**Medio**	Verificado	Realtime desencadena recargas completas y sin versionado ante cambios en seis tablas.
AUD-2026-04	**Medio**	Verificado	Bootstrap privilegiado no es atómico; puede dejar una organización/membresía parcial.

AUD-2026-05	**Medio**	Verificado	DCF no informa un crecimiento terminal no finito; devuelve resultados `null` sin advertencia.
AUD-2026-06	**Medio**	Verificado en desarrollo	Faltan cabeceras HTTP defensivas visibles en `localhost`; hay que comprobar y fijar producción.
AUD-2026-07	**Medio**	Verificado	JSON/CSV grandes se parsean completos en el hilo principal antes de limitar filas y se copian al Worker.
AUD-2026-08	**Medio**	Riesgo plausible	`connection_config` es legible por el cliente: no debe contener nunca secretos futuros.
AUD-2026-09	**Bajo**	Verificado	Falta un script de pruebas/CI estable; una prueba CSV permanece no ejecutable directamente.
AUD-2026-10	**Bajo**	Verificado	Los parsers CSV toleran comillas sin cerrar y realizan parsing completo en memoria.

4. Hallazgos detallados

AUD-2026-01 — Inyección de fórmulas en CSV

Severidad: Alto. `src/lib/local-analytics.ts` genera CSV mediante comillas y escape de comillas, pero no neutraliza campos que comienzan por `=`, `+`, `-` o `@`. `LocalCanvasWorkspace.tsx` usa el mismo patrón para exportar el dataset editable. `src/lib/crypto-tax.ts` usa un escape equivalente para el borrador fiscal. Una comprobación aislada devolvió, por ejemplo,

`"=HYPERLINK(\"\"https://example.invalid\"\" )"` en el CSV del Canvas y `"=1+1"` en el campo del ejercicio de cripto.

La precondición es que una persona abra en una hoja de cálculo un CSV creado con texto no confiable, por ejemplo importado desde una fuente o escrito en una celda. La ejecución depende de la aplicación de hoja de cálculo y de su configuración, pero el vector no está neutralizado. OWASP identifica esta situación como CSV/Formula Injection y explica que entrecomillar por sí solo no basta; para consumo humano recomienda anteponer un carácter que fuerce interpretación textual y tratar cuidadosamente los separadores. [1]

Corrección mínima. Centralizar una función `safeSpreadsheetCell` para Canvas, cripto y cualquier exportador futuro. Debe tratar los caracteres iniciales `=`, `+`, `-`, `@`, tabulador, retorno y salto de línea, escapar comillas y documentar el compromiso de compatibilidad. Para CSV destinado a apertura humana en Excel, OWASP documenta el prefijo de tabulación dentro de una celda entrecomillada como una mitigación resistente a ciertos flujos de re-guardado; para CSV de reimportación programática se debe mantener un formato separado, controlado y no abierto como hoja de cálculo. [1]

Prueba de regresión requerida. Introducir una cadena `=1+1`, `+1+1`, `-1+1`, `@SUM(A1:A2)` y una que contenga separador/comillas; verificar que ningún campo exportado comienza por un iniciador de fórmula tras el parseo estándar de CSV.

AUD-2026-02 — Fecha cripto sintácticamente válida pero semánticamente imposible

Severidad: Alto. `operationsFromCsv` en `src/lib/crypto-tax.ts` valida la fecha con `/^\d{4}-\d{2}-\d{2}$/`, sin comprobar que represente un día del calendario. La prueba aislada importó `2026-99-99,Compra,BTC,1,100`; el resultado no incluyó advertencias, creó una tenencia de BTC por coste 100 y dejó `unsupportedRows` en cero.

El impacto no es una intrusión, sino un error de cálculo y trazabilidad fiscal: una operación imposible puede ordenarse lexicográficamente y afectar FIFO, informes y borradores. En una aplicación financiera, la validación necesita ser tanto sintáctica como semántica; OWASP recomienda validar la forma y también la corrección del valor en su contexto antes de procesarlo. [2]

Corrección mínima. Reutilizar una normalización de calendario como la ya existente en `normalizeLocalDate`, pero exigir `AAAA-MM-DD` en cripto. La operación debe quedar en `unsupportedRows`, no crear lote y mostrar una advertencia con `rowNumber`. Añadir también un rango razonable de fecha configurable por ejercicio fiscal, si el producto lo necesita.

AUD-2026-03 — Recarga integral por ráfagas Realtime

Severidad: Medio. `RealtimePortfolioApp.tsx` se suscribe a seis tablas y llama a `loadWorkspace()` con cada evento. La función vuelve a consultar instantáneas, posiciones,

alertas, fuentes, transacciones —hasta 5.000—, análisis y reglas, aunque el cambio proceda de una sola tabla. No existe `requestId`, `AbortController`, debounce/coalescencia ni segmentación de consultas para este flujo autenticado.

Una ráfaga de eventos puede multiplicar lecturas, producir estado transitorio y permitir que una respuesta anterior llegue después de una más reciente. Esto no rompe RLS por sí mismo, pero perjudica disponibilidad, coste y consistencia percibida.

Corrección mínima. Crear un planificador de actualizaciones con ventana corta de coalescencia, identificador monotónico y cancelación. Cada evento debe invalidar solo su dominio: alertas, fuentes, instantáneas, posiciones o análisis. La vista debe aceptar la respuesta solo si coincide con la versión de solicitud vigente. Mantener paginación para transacciones e instrumentar p95 de recarga y número de consultas por ráfaga.

AUD-2026-04 — Bootstrap de organización no transaccional

Severidad: Medio. La Edge Function `bootstrap-organization` valida la sesión correctamente con el token `Authorization`, pero usa el cliente de servicio para ejecutar una secuencia de perfil, organización, membresía, cartera y auditoría. Si falla la membresía, elimina la organización; si falla la cartera después de una membresía válida, devuelve error sin revertir la organización ni la membresía. La verificación previa de membresía puede entonces bloquear el reintento de la cuenta.

Corrección mínima. Mover la operación a una única RPC de PostgreSQL con transacción, o hacer el endpoint idempotente: detectar una organización incompleta de la misma persona y completar o revertir de forma determinista. Añadir un índice/garantía de negocio explícita sobre la pertenencia inicial, manejo de conflictos y una prueba de fallo forzado en cada paso. La función debe conservar la auditoría, pero el error de auditado no debería invalidar silenciosamente el estado principal sin una política definida.

AUD-2026-05 — Rechazo silencioso de supuesto DCF no finito

Severidad: Medio. `calculateDcf` comprueba que `discountRate` sea finito, pero no comprueba que `terminalGrowthRate` lo sea. Al pasar `NaN` como crecimiento terminal, la comprobación `discountRate <= terminalGrowthRate` no se activa; los cálculos terminan en `NaN`, `safeRound` los vuelve `null`, y `warnings` queda vacío.

Corrección mínima. Validar `finite(terminalGrowthRate)` además de su rango, antes de cualquier cálculo. Si el valor es inválido, devolver todas las métricas `null` junto con un mensaje específico. Agregar pruebas para `NaN`, infinito, crecimiento terminal igual/superior al descuento y acciones no válidas.

AUD-2026-06 — Cabeceras de defensa no verificadas en el despliegue

Severidad: Medio en desarrollo; pendiente de confirmación en producción. La respuesta de `curl -I http://localhost:3000/` incluyó `X-Powered-By: Next.js`, pero no CSP, `X-Content-Type-Options`, `Referrer-Policy`, `Permissions-Policy`, `X-Frame-Options` ni una política `frame-ancestors`. El resultado de desarrollo no prueba que producción carezca de ellas: un CDN, reverse proxy o configuración de hosting puede añadirlas. Aun así, no hay una configuración de cabeceras en el árbol local que las haga reproducibles.

OWASP documenta estas cabeceras como defensas adicionales ante XSS, clickjacking, sniffing MIME, filtración de referrer y capacidades del navegador; también aconseja no revelar `X-Powered-By`. 3

Corrección mínima. Declarar una política en el host de producción o `next.config` y validarla con una prueba de despliegue. La CSP debe diseñarse por rutas y probarse primero en `Report-Only`, ya que Supabase, fuentes, PDF y recursos de desarrollo pueden requerir orígenes concretos. Para áreas autenticadas, definir además política de caché apropiada y confirmar TLS/HSTS en el borde.

AUD-2026-07 — Pico de memoria en importaciones/restauraciones locales grandes

Severidad: Medio. Canvas limita cada archivo a 15 MB y 100.000 filas, una defensa útil. No obstante, `file.text()` y `JSON.parse()` construyen primero todo el texto/objeto en el hilo principal; después el estado se normaliza y se copia al Worker. Un archivo por debajo de 15 MB puede seguir provocar un pico temporal de memoria o pausa en equipos limitados. El mismo patrón aplica a CSV cripto —con límite de 15 MB/50.000 operaciones— y a XLSX mediante `read-excel-file`.

Corrección mínima. Adoptar el parser NDJSON incremental ya documentado como alternativa de sesiones grandes, mover parseo y normalización a un Worker, devolver al hilo principal solo agregados y las primeras filas necesarias para la tabla, e incorporar cancelación/progreso. Mantener límites configurables y medir memoria/latencia en navegadores objetivo antes de ampliar los umbrales.

AUD-2026-08 — `connection_config` no debe evolucionar hacia un almacén de secretos

Severidad: Medio, riesgo de diseño. El cliente selecciona `connection_config` de `data_sources` y lo coloca en `Workspace`. Actualmente se usa para URL/ID de hoja, pestaña, rango y mapeo, sin tokens. Esta elección es compatible con la configuración pendiente actual. El riesgo aparece si se añaden credenciales OAuth, DSN de SQL, secretos de API o refresh tokens a ese JSON: los miembros con permiso de lectura de fuentes recibirían esos valores.

Corrección mínima. Mantener en `data_sources` solo metadatos no sensibles y guardar secretos únicamente en vault/variables de Edge Function, referenciados por identificador opaco. Añadir un tipo de configuración pública con allowlist y una prueba que rechace claves como `token`, `secret`, `password`, `refresh_token`, `api_key` o `connection_string` antes de insertar. Toda sincronización futura debe operar server-side con rol de conector limitado.

AUD-2026-09 — Regresiones no integradas en un runner de CI estable

Severidad: Bajo. `package.json` no declara `test` ni `typecheck`; las pruebas se ejecutan manualmente con type stripping experimental. La comprobación de CSV de Salud empresa existe, pero no quedó ejecutable directamente por resolución ESM de importaciones de tipo y no debe contarse como cobertura validada.

Corrección mínima. Elegir un runner TypeScript explícito —sin instalarlo hasta aprobar la dependencia—, añadir scripts `test`, `test:unit`, `test:security` y una matriz mínima de CI. El CI debería bloquear por exportación CSV insegura, fecha calendario imposible, DCF no finito, aislamiento local, reglas RLS y respuestas Realtime obsoletas.

AUD-2026-10 — Tolerancia excesiva del parser CSV

Severidad: Bajo. Los parsers de Canvas y cripto implementan CSV ligero en memoria. Admiten comillas escapadas, pero no marcan comillas sin cerrar ni distinguen errores de estructura de una celda larga. Actualmente el daño queda acotado al navegador y los límites de tamaño reducen el riesgo, pero el cálculo podría tratar un archivo malformado como datos ambiguos.

Corrección mínima. Añadir estado de error si finaliza con `quoted === true`, límites de longitud por línea/celda y pruebas de delimitadores, comillas y UTF-8. Para volúmenes grandes, sustituir el parser por una ruta incremental con validación de esquema.

5. Controles correctos verificados

Área	Control verificado	Evidencia
Secretos locales	`.gitignore` ignora `.env*`; se identificaron por nombre solo URL y clave publicable de Supabase.	Inventario local sin lectura de valores.
Cliente Supabase	Solo usa URL y clave publicable `NEXT_PUBLIC`; el rol de servicio se encuentra en la función Edge.	`src/lib/supabase.ts` y `bootstrap-organization`.

Edge Function	Rechaza métodos distintos de POST, exige `Authorization`, valida usuario y limita origen a `APP_ORIGIN`/localhost.	`supabase/functions/bootstrap-organization/index.ts`.
RLS declarada	Tablas con RLS y helpers privados `security definer` con `search_path` explícito.	Migraciones locales; no revalidado en vivo.
Canvas privado	Sin `localStorage`, Supabase o IA por diseño; Worker con `requestId`; el navegador no registró recursos externos al abrir el ejemplo.	Revisión de código y `performance.getEntriesByType('resource')`.
Entrada local	Límites de 15 MB, topes de fila y validación de celdas antes de recálculo.	Canvas y regresiones.
Validación accesible	Celda `abc` mantuvo KPI en 741 €, mostró error y tuvo `aria-invalid="true"` con `aria-describedby`.	Recorrido visual con datos ficticios.
Accesibilidad de base	Labels, botones tipo explícito, mensajes `role="status"` / `alert`, foco visible y tooltip accesible por foco.	Revisión estática de componentes y CSS.
Dependencias	Sin vulnerabilidades de producción detectadas por `npm audit` en la ejecución.	Resultado de auditoría npm.

6. Privacidad y fronteras de datos

Contexto	Comportamiento verificado	Riesgo residual	Acción necesaria
Canvas sin cuenta	Datos en memoria, Worker local y descargas explícitas.	Descargas se guardan en el dispositivo del usuario; archivos grandes pueden presionar memoria.	Mantener aviso, endurecer CSV y migrar importación grande a streaming.

Cripto local	CSV local, FIFO local y borrador descargable.	Fecha inválida y CSV formula injection.	Corregir AUD-2026-01 y AUD-2026-02 antes de presentar el borrador como robusto.
Salud empresa	Valores manuales en estado React, exportación local y tooltips.	No valida la fuente externa; PDF no es una verificación independiente.	Añadir sello de procedencia y pruebas de exportación.
Dashboard autenticado	Datos persistentes con RLS declarada y sesión Supabase persistida por SDK.	Falta revalidar RLS en el proyecto vivo y aplicar cabeceras de despliegue.	Pruebas multiusuario ficticias y validación de producción.
Conectores futuros	Solo se guarda configuración pendiente hoy.	Exposición si se ponen secretos en `connection_config`.	Secretos backend/vault y adaptador R/O.

7. Accesibilidad y experiencia

La revisión visual del Canvas mostró una entrada alternativa sin cuenta, aviso de privacidad, botones con nombre accesible, controles de carga y un ejemplo ficticio. Después de abrirlo, la tabla editable expuso etiquetas por fila/campo, los errores tuvieron asociación ARIA y el dashboard no cambió ante un importe inválido. No se detectaron imágenes sin atributo `alt` en `src`.

La base de foco visible existe con reglas `:focus-visible` globales y estilos específicos de tooltip. Los tooltips de fórmulas se muestran con `:focus-within`, lo que permite activación por teclado. Las acciones deshabilitadas de exportación e informe se muestran cuando falta cobertura o instantánea.

No obstante, la auditoría no equivale a conformidad WCAG: faltan pruebas con lector de pantalla, navegación completa solo con teclado, contraste medido, orden de foco en tablas de 200 entradas, tamaños de pantalla móvil y recorrido autenticado. Se recomienda añadir pruebas E2E y una lista de aceptación WCAG 2.2 AA por pantalla crítica.

8. Plan de remediación priorizado

Horizonte	Acciones	Criterio de cierre
Inmediato — antes de publicar	Corregir CSV injection; validar fechas calendario de cripto;	Pruebas negativas pasan y ninguna exportación pública

	validar `terminalGrowthRate`; añadir regresiones para los tres casos.	deja iniciadores de fórmula sin neutralizar.
Corto plazo	Coalescer/versionar Realtime, paginar transacciones, convertir bootstrap en RPC transaccional idempotente.	Prueba de ráfaga mantiene último estado; fallo forzado de bootstrap no deja registros parciales.
Corto plazo	Configurar cabeceras en hosting/Next y probar producción; revisar secret boundary de `connection_config`.	Cabeceras comprobadas en URL pública; ningún secreto llega a una consulta de cliente.
Medio plazo	NDJSON/Worker para datos grandes, parser CSV más estricto y telemetría local opcional/anónima solo con consentimiento.	Archivo malformado se rechaza; importación grande no bloquea la interfaz de referencia.
Medio plazo	Runner estable, E2E y pruebas de accesibilidad/RLS con usuarios ficticios.	CI bloquea hallazgos Altos y muestra una matriz de regresión reproducible.
Antes de conectores, IA o cotizaciones	RLS remota revisada, secretos en backend, licencia de fuente, auditoría de solicitudes y consentimiento de ámbito.	No existen claves en cliente ni herramientas de escritura; cada dato tiene fuente, fecha y cobertura.

9. Matriz de regresión recomendada

Caso	Resultado esperado
Campo CSV que inicia por `=`, `+`, `-`, `@`, tab o salto de línea	Exportación neutra para hoja de cálculo y formato de reimportación separado/documentado.
Compra cripto con `2026-99-99` o `2026-02-30`	Fila bloqueada, advertencia con número de fila, sin lote ni efecto en resumen.
DCF con `NaN`, infinito o crecimiento ⩾ descuento	Sin valoración y con advertencia específica.
Diez eventos Realtime simultáneos	Una carga coalescida; ninguna respuesta antigua sustituye la más nueva.

Fallo de cartera durante bootstrap	Transacción revertida o reintento idempotente que completa estado.
JSON de 15 MB / más de 100.000 filas	Rechazo o progreso sin congelar la UI; estado existente intacto.
Editor, viewer y usuario de otra organización	RLS permite solo las operaciones esperadas; no hay lectura entre organizaciones.
Canvas con ejemplo ficticio	Sin recursos externos, sin storage persistente y errores ARIA asociados.

10. Limitaciones y próximos pasos de auditoría

Esta revisión no descubrió un secreto expuesto ni un bypass RLS confirmado. Tampoco puede demostrar que producción tenga o no las cabeceras, WAF, TLS, políticas de cookies y RLS declaradas localmente. La ausencia de `.git` en la copia restaurada impide atribuir hallazgos a un commit o producir un diff fiable frente a `main`.

La siguiente auditoría debe ejecutarse después de corregir los hallazgos Altos y antes de publicar: incluir pruebas RLS con dos organizaciones ficticias, un entorno de staging que permita inspeccionar cabeceras reales, pruebas E2E de Canvas/cripto/Salud empresa, y un análisis de dependencias bloqueado en lockfile. No se deben activar conectores de mercado, OAuth de Google Sheets, bases SQL externas, Power BI Embedded, IA o exportación fiscal oficial hasta cerrar los controles de frontera correspondientes.

Referencias

[1] OWASP — CSV Injection
[2] OWASP Cheat Sheet Series — Input Validation
[3] OWASP Cheat Sheet Series — HTTP Security Response Headers